Contents

Volume 03 — Metasploit, MITM & Crypto I (L21–L30) **1**
L21: Metasploit — Exploiting System Software I 1
L22: Metasploit — Exploiting System Software II 2
L23: Metasploit — Exploiting System Software and Privilege 2
L24: Metasploit — Social Engineering Attack 3
L25: MITM (Man-in-the-Middle) Attack 3
L26: Basic Concepts of Cryptography 4
L27: Private-Key Cryptography — Part I 4
L28: Private-Key Cryptography — Part II 5
L29: Public-Key Cryptography — Part I 6
L30: Public-Key Cryptography — Part II 6

Volume 03 — Metasploit, MITM & Crypto I (L21–L30)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Exploitation frameworks, social engineering, ARP/MITM, cryptography foundations.

L21: Metasploit — Exploiting System Software I

What it is / what it does

- **Metasploit Framework (MSF):** open-source penetration testing platform by Rapid7.
- **Architecture:** msfconsole (CLI) → modules (exploits, payloads, auxiliaries, encoders, nops, post) → database.
- **Exploit module:** delivers payload against a specific vulnerability (CVE).
- **Payload:** code executed on target after exploitation (shell, meterpreter, VNC).
- **msfvenom:** standalone payload generator and encoder.

Defenses (one-liners)

- Patch management (MS17-010 for EternalBlue)
- Disable SMBv1
- Network segmentation; block inbound SMB (port 445) at perimeter
- EDR detecting Meterpreter behavior

Exam lines

- Metasploit modules: **exploit, payload, auxiliary, encoder, post**.
- msfvenom generates standalone payloads outside msfconsole.
- Meterpreter = advanced in-memory payload with extensible features.
- set RHOSTS = target; set LHOST = attacker callback IP.

L22: Metasploit — Exploiting System Software II

What it is / what it does

- **Auxiliary modules:** scanning, fuzzing, DoS, credential brute-force (no payload delivery).
- **Encoder modules:** obfuscate payload to evade signature-based AV/IDS.
- **NOP generators:** pad payload to avoid bad-character issues.
- **Resource scripts (.rc):** automate sequences of MSF commands.
- **Multi/handler:** catch reverse connections from multiple exploits.

Defenses (one-liners)

- AV with behavioral detection (not just signatures)
- Application whitelisting
- Network monitoring for reverse shell connections
- Disable unnecessary services found by auxiliary scans

Exam lines

- **Auxiliary modules** perform scanning/brute-force without delivering exploits.
- **Encoders** (e.g., shikata_ga_nai) mutate payload to evade detection.
- exploit/multi/handler catches reverse TCP connections.
- Resource scripts automate repetitive msfconsole commands.
- show options displays required/optional module parameters.

L23: Metasploit — Exploiting System Software and Privilege

What it is / what it does

- **Privilege escalation:** gaining higher permissions (user → root/SYSTEM).
- **Post-exploitation modules:** run after initial access (hashdump, enum_users, persistence).
- **Meterpreter commands:** sysinfo, getuid, getsystem, hashdump, migrate.
- **Local exploits:** target OS/kernel vulnerabilities from low-privilege shell.
- **Token impersonation:** steal SYSTEM token on Windows.

Defenses (one-liners)

- Principle of least privilege
- Patch kernel and local privilege escalation CVEs promptly
- Credential Guard / LSA protection (Windows)
- Monitor for suspicious token manipulation

Exam lines

- getsystem attempts multiple techniques to gain SYSTEM on Windows.
- hashdump extracts NTLM password hashes from SAM database.
- **Post modules** run after compromise (enumeration, persistence, exfiltration).
- migrate moves Meterpreter into a more stable process (e.g., explorer.exe).
- local_exploit_suggester recommends kernel exploits based on system info.

L24: Metasploit — Social Engineering Attack

What it is / what it does

- **Social engineering:** manipulating people to divulge info or perform actions.
- **SET (Social Engineering Toolkit):** integrated with Metasploit for phishing campaigns.
- **Attack vectors:** spear phishing, USB drops, fake login pages, SMS phishing (smishing).
- **Credential harvester:** clone legitimate website; capture submitted credentials.
- **Payload delivery via email:** malicious attachment or link to browser exploit.

Defenses (one-liners)

- Security awareness training and phishing simulations
- Email filtering (SPF, DKIM, DMARC)
- MFA on all authentication endpoints
- URL rewriting/proxy for link inspection

Exam lines

- SET integrates with Metasploit for **automated social engineering**.
- Credential harvester **clones websites** to steal login credentials.
- Spear phishing targets **specific individuals** with crafted messages.
- MFA mitigates stolen-credential attacks even after successful harvest.
- Social engineering exploits **human psychology**, not technical vulnerabilities.

L25: MITM (Man-in-the-Middle) Attack

What it is / what it does

- **MITM:** attacker intercepts and potentially alters communication between two parties.
- **ARP spoofing/poisoning:** send fake ARP replies mapping attacker's MAC to victim's gateway IP.
- **DNS spoofing:** redirect DNS queries to attacker-controlled server.
- **SSL stripping:** downgrade HTTPS to HTTP (sslstrip tool).
- **Session hijacking:** capture cookies/tokens from intercepted traffic.

Defenses (one-liners)

- **Static ARP entries** for critical hosts (gateway, DNS)
- **Dynamic ARP Inspection (DAI)** on managed switches
- **HTTPS with HSTS** and certificate pinning
- **802.1X** port authentication

Exam lines

- ARP operates at **Layer 2**; has no authentication — easily spoofed.
- Bidirectional ARP spoofing required: poison victim **and** gateway.
- IP forwarding must be enabled on attacker to relay packets.
- DAI on switches validates ARP packets against DHCP snooping table.
- SSL stripping exploits sites that don't enforce HSTS.

L26: Basic Concepts of Cryptography

What it is / what it does

- **Cryptography goals:** confidentiality, integrity, authentication, non-repudiation.
- **Kerckhoffs's principle:** security relies on key secrecy, not algorithm secrecy.
- **Cryptanalysis:** breaking ciphers without key (brute force, frequency analysis, side channels).
- **Symmetric vs asymmetric:** same key vs key pair (public/private).
- **Steganography vs cryptography:** hiding existence of message vs scrambling content.

Defenses (one-liners)

- Use well-vetted algorithms (AES, SHA-256, RSA-2048+)
- Proper key management (HSM, key rotation)
- Never roll your own crypto
- Use authenticated encryption (AES-GCM, ChaCha20-Poly1305)

Exam lines

- Kerckhoffs's principle: algorithm is public; **key is secret**.
- Symmetric crypto: **one shared key** for encrypt and decrypt.
- Asymmetric crypto: **public key encrypts**, private key decrypts.
- Steganography hides message **existence**; cryptography hides **content**.
- Brute-force complexity grows exponentially with key length.

L27: Private-Key Cryptography — Part I

What it is / what it does

- **Symmetric (private-key) ciphers:** AES, DES, 3DES, Blowfish, RC4.

- **Block ciphers:** encrypt fixed-size blocks (AES = 128-bit blocks).
- **Stream ciphers:** encrypt bit/byte at a time (RC4, ChaCha20).
- **DES:** 56-bit key (obsolete); **3DES:** three DES operations (deprecated).
- **AES (Rijndael):** 128/192/256-bit keys; NIST standard since 2001.

Defenses (one-liners)

- Use AES-256 in GCM or CBC with HMAC
- Never use DES, 3DES, or RC4 in new systems
- Unique IV/nonce per encryption operation
- Key length ≥ 256 bits for long-term security

Exam lines

- AES block size = **128 bits**; key sizes = 128, 192, or 256 bits.
- DES key = **56 effective bits** (64 with parity) — considered broken.
- ECB mode reveals patterns — **never use for structured data**.
- Stream ciphers encrypt data **bit-by-bit** or byte-by-byte.
- 3DES applies DES encrypt-decrypt-encrypt (EDE) with 2 or 3 keys.

L28: Private-Key Cryptography — Part II

What it is / what it does

- **Block cipher modes:** ECB, CBC, CFB, OFB, CTR, GCM.
- **CBC (Cipher Block Chaining):** each block XORed with previous ciphertext; requires unique IV.
- **CTR (Counter mode):** turns block cipher into stream cipher; parallelizable.
- **GCM (Galois/Counter Mode):** authenticated encryption (AEAD) — confidentiality + integrity.
- **Key distribution problem:** symmetric crypto requires secure key exchange channel.

Defenses (one-liners)

- Prefer **AES-GCM** or **ChaCha20-Poly1305** (authenticated encryption)
- Random, unique IV for every CBC/CTR encryption
- Never reuse nonce in GCM (catastrophic failure)
- Use TLS 1.3 for transport encryption

Exam lines

- CBC chains blocks: $C_i = E(P_i \oplus C_{i-1})$; requires unpredictable **IV**.
- GCM provides **authenticated encryption** (confidentiality + integrity).
- CTR mode converts block cipher into **stream cipher**; supports parallel encryption.
- Padding oracle attack exploits **CBC decryption error messages**.
- Symmetric crypto's weakness: **secure key distribution** between parties.

L29: Public-Key Cryptography — Part I

What it is / what it does

- **Asymmetric cryptography:** key pair — public key (encrypt/verify) + private key (decrypt/sign).
- **RSA:** based on factoring large primes; key sizes 2048–4096 bits recommended.
- **Diffie-Hellman (DH):** key exchange protocol; compute shared secret over insecure channel.
- **ECDHE:** Elliptic Curve DH Ephemeral — modern TLS key exchange.
- **One-way functions:** easy to compute forward, infeasible to reverse (factoring, discrete log).

Defenses (one-liners)

- RSA key length ≥ **2048 bits** (3072+ for long-term)
- Use ECDHE with curve P-256 or X25519
- Disable export-grade and weak DH cipher suites
- Rotate keys periodically

Exam lines

- RSA security based on **integer factorization** hardness.
- DH allows **key exchange** without prior shared secret.
- Public key encrypts; **only private key decrypts**.
- ECDHE uses **elliptic curve** math for smaller, faster keys.
- RSA-1024 is deprecated; minimum is **RSA-2048**.

L30: Public-Key Cryptography — Part II

What it is / what it does

- **Hybrid encryption:** asymmetric for key exchange + symmetric for bulk data (TLS model).
- **RSA padding schemes:** PKCS#1 v1.5, OAEP (prevent chosen-ciphertext attacks).
- **ElGamal:** encryption based on discrete logarithm problem.
- **Elliptic Curve Cryptography (ECC):** same security as RSA with smaller keys (P-256 ≈ RSA-3072).
- **Key management:** PKI, certificate authorities, certificate chains (covered L33).

Defenses (one-liners)

- Use RSA-OAEP or ECIES for encryption
- Validate elliptic curve points in ECDH implementations
- Hardware RNG or OS CSPRNG for key generation
- Certificate pinning for critical applications

Exam lines

- Hybrid encryption: **asymmetric exchanges key**, symmetric encrypts data.
- ECC P-256 provides security equivalent to **RSA-3072** with smaller keys.
- OAEP padding prevents **chosen-ciphertext attacks** on RSA.
- ElGamal encryption based on **discrete logarithm** problem.
- TLS uses hybrid model: ECDHE key exchange + AES-GCM bulk encryption.